

Evidence Matrix

Requirement-level evidence expectations, accountable owners and simulated readiness status.

Document ID	PCI-V2-EM-004
Prepared by	Richmond Kwadwo Sarpong
Case study	Akwaaba Retail & Online Ltd. (fictional)
Date / version	20 August 2026 / Version 2.0

Independent fictional portfolio case study - not a Report on Compliance, Attestation of Compliance, QSA assessment, or evidence of work performed for a real merchant.

Evidence Management Principle

Evidence should be dated, attributable, complete, securely stored, and reproducible by an independent reviewer. A policy statement alone does not demonstrate operating effectiveness; supporting system output, tickets, review records, test results and approvals are expected where applicable.

Req.	Control theme	Expected evidence	Accountable owner	Readiness
1	Network security controls	Network and data-flow diagrams; firewall standards; rule exports; approvals; six-month reviews	Network Lead	Partial
2	Secure configurations	Approved baselines; build records; configuration scans; change tickets; default-account review	Infrastructure Lead	Partial
3	Stored account data	Data discovery results; retention schedule; deletion logs; PAN masking tests; key-management records	Data Owner	Missing
4	Transmission protection	TLS configuration reports; certificates; endpoint scans; wireless and remote-access configurations	Network Lead	Partial
5	Malware protection	Coverage inventory; console health report; policy; alert samples; exclusion review	Security Operations	Partial
6	Secure systems and software	Vulnerability reports; patch evidence; SDLC procedure; code review; WAF; script inventory and approvals	Engineering Lead	Partial
7	Business-need access	Role matrix; access requests; approvals; service-account ownership; periodic access reviews	System Owners	Partial
8	Identification and authentication	User inventory; MFA policy and logs; password settings; vendor access; account lifecycle samples	IAM Lead	Partial
9	Physical access	Site access list; visitor logs; CCTV retention; POS inventory; device inspection records	Facilities / Retail Ops	Partial
10	Logging and monitoring	Log-source inventory; SIEM rules; daily review tickets; time synchronization; retention and retrieval test	Security Operations	Missing
11	Security testing	ASV reports; internal scans; penetration and segmentation tests; wireless scans; tamper alerts	Security Manager	Missing
12	Security program	Policies; annual risk assessment; targeted risk analyses; TPSP AOCs; responsibility matrix; training; IR exercise	Compliance Lead	Partial

Evidence Quality Checklist

Quality attribute	Reviewer question
Current	Does the evidence cover the assessment period and required frequency?
Attributable	Can the reviewer identify the source, owner, date and system?
Complete	Does the sample cover the full scoped population or an appropriate sample?
Protected	Is evidence stored with access control and integrity protection?
Reproducible	Could an independent reviewer repeat the test and reach the same conclusion?
Traceable	Is the evidence linked to the requirement, finding, risk and remediation record?

Acronyms and Definitions

Document-specific reference glossary for **Evidence Matrix**. Definitions are written in plain language for recruiters, reviewers and non-specialist readers.

Acronym	Full meaning and explanation
AOC	Attestation of Compliance A formal declaration that applicable PCI DSS requirements have been assessed.
ASV	Approved Scanning Vendor A company approved by the PCI SSC to perform external vulnerability scanning services.
CDE	Cardholder Data Environment The people, processes and technologies that store, process or transmit cardholder data, or can affect its security.
CHD	Cardholder Data At minimum, the primary account number; it may also include the cardholder name, expiration date or service code.
MFA	Multi-Factor Authentication Authentication using at least two different factor types before access is granted.
NTP	Network Time Protocol A protocol used to synchronize system clocks for reliable logs and investigations.
PAN	Primary Account Number The payment card number that identifies the issuer and cardholder account.
PCI DSS	Payment Card Industry Data Security Standard The global security standard for protecting payment account data.
QSA	Qualified Security Assessor A PCI SSC-qualified organization or individual that performs PCI DSS assessments.
RACI	Responsible, Accountable, Consulted and Informed A matrix used to clarify roles and decision ownership.
ROC	Report on Compliance A detailed report documenting the results of a PCI DSS assessment.
SAQ	Self-Assessment Questionnaire A validation tool for eligible entities to document PCI DSS self-assessment results.
SIEM	Security Information and Event Management Technology that centralizes and analyzes security logs and alerts.
TPSP	Third-Party Service Provider An external provider whose services store, process, transmit or can affect the security of account data.

Portfolio note: This glossary supports a fictional PCI DSS v4.0.1 readiness case study and does not represent a formal compliance determination.